

IS APPLICATION SERVICE DELIVERY ORGANIZATION

Contents

1. Contexto de la Organización	4
1.1. Objetivos, Misión y Visión	4
1.1.1. Misión	4
1.1.2. Visión	4
1.1.3. Objetivos	4
1.2. Fundación y Cuerpo Académico	4
1.2.1. Fundación	4
1.2.2. Cuerpo Académico (I+D)	4
1.3. Organigrama	5
2. Alcance	6
2.1. Análisis del Área	6
2.2. Proceso elegido	6
2.3. Activo elegido	6
2.4. Límite del Alcance	6

PROJECT NAME	BASED ON			
IS APPLICATION SERVICE DELIVERY ORGANIZATION	Not Defined			
PROJECT ID.	EXTERNAL DOCUMENT ID.			
0001				
CUSTOMER	REFERENCE DESIGNATION			
UPSLP	N/A			
PREPARED	STATUS	SECURITY LEVEL		
2026-04-28 177622 - Cruz Juárez Francisco, 179033 - Alonso Castillo Omar, 175031 - Espinoza Aguilar Brian Salvador, 177685 - Martínez Lara Santiago de la Cruz, 173030 - Sánchez Ramírez Mayeli, 177263 - Sánchez Zavala Alan Gilberto	Draft	Internal		
APPROVED	DOCUMENT KIND			DCC
2026-04-29	Click or tap here to enter text.			Click or tap here to enter text.
OWNING ORGANIZATION	DOCUMENT ID.	REV.	LANG.	PAGE
		A	en	1/26

2.5.	Referencias Normativas	6
3.	Términos y Condiciones	7
4.	Contexto de la Organización - Inventario de Activos	8
4.1.	Contexto Interno	8
4.2.	Contexto Externo	8
5.	Liderazgo	9
5.1.	Bloque 1: 10 Políticas para Activos Internos	9
5.1.1.	Política de Control de Acceso (Activo: Credenciales de Acceso):	9
5.1.2.	Política de Desarrollo Seguro (Activo: Código fuente de aplicaciones):	9
5.1.3.	Política de Gestión de Almacenamiento (Activo: Servidores de Almacenamiento):	9
5.1.4.	Política de Respaldo de Datos (Activo: Backups locales):	10
5.1.5.	Política de Monitoreo de Seguridad (Activo: Logs de auditoría):	10
5.1.6.	Política de Protección de la Privacidad (Activo: Bases de datos PII):	10
5.1.7.	Política de Documentación Técnica (Activo: Manuales y Planos):	10
5.1.8.	Política de Configuración de Red (Activo: Configuraciones de Switches/Firewalls):	10
5.1.9.	Política de Formación de Personal (Activo: Personal y ética técnica):	10
5.1.10.	Política de Salud de Activos (Activo: Estaciones de trabajo de ingeniería):	10
5.2.	Bloque 2: 10 Políticas para Activos Externos	11
5.2.1.	Política de Seguridad en la Nube (Activo: Servicios Cloud Azure/AWS):	11
5.2.2.	Política de Gestión de Riesgos de Proveedores (Activo: Soporte técnico TIC externo):	11
5.2.3.	Política de Cumplimiento Regulatorio (Activo: Leyes de Protección de Datos):	11
5.2.4.	Política de Integridad de Suministros (Activo: Repuestos originales OEM):	11
5.2.5.	Política de Inteligencia de Amenazas (Activo: Inteligencia de amenazas externa):	11
5.2.6.	Política de Software de Terceros (Activo: Licencias de software externas):	11
5.2.7.	Política de Continuidad de Servicios Críticos (Activo: Suministro de energía externa):	12
5.2.8.	Política de Intercambio Seguro (Activo: Datos de configuración de clientes):	12
5.2.9.	Política de Uso de Código Abierto (Activo: Bibliotecas de código abierto):	12
5.2.10.	Política de Gestión de Auditorías Externas (Activo: Certificaciones ISO 27001):	12
6.	Matriz de Riesgo de Seguridad	12
6.1.	Desglose de Evaluación de los 20 Activos	13
6.2.	Resumen Estadístico de Riesgos	14

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	2/26

7. SOPORTE - MINUTA DE AVANCES (S1-S6)	14
7.1. INTEGRANTES DEL EQUIPO DE INVESTIGACIÓN	15
7.2. RESUMEN DE AVANCES DE INVESTIGACIÓN (SECCIONES 1-7)	15
7.3. ACUERDOS DE LA SESIÓN DE INVESTIGACIÓN	16
7.4. FIRMAS DE CONFORMIDAD	16
8. OPERACIÓN	18
8.1. Planificación y Control Operacional	18
8.1.1. Preparación y Validación	19
8.1.2. Ejecución Técnica (El "Hacer")	19
8.2. Tratamiento de los Riesgos para la Seguridad de la Información	19
8.3. Mapa de Implementación Tangible (Checklist de Verificación)	20
8.4. Gestión del Cambio Operacional	20
9. EVALUACIÓN DEL DESEMPEÑO	21
9.1. Seguimiento, Medición, Análisis y Evaluación	21
9.2. Auditoría Interna: Checklist de Cumplimiento	21
9.3. Revisión por la Dirección	22
9.3.1. Puntos clave de la revisión:	22
9.3.2. Instrucciones para tu defensa:	22
10. MEJORA	22
10.1. Gestión de No Conformidades y Acciones Correctivas	22
10.2. Mejora Continúa	23
10.3. Conclusión General del Proyecto de Investigación	23

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	3/26

1. Contexto de la Organización

1.1. Objetivos, Misión y Visión

1.1.1. Misión¹

ABB tiene como misión principal impulsar la transformación de la sociedad y la industria para lograr un futuro más productivo y sostenible mediante la electrificación y automatización.

1.1.2. Visión²

Consolidarse como el socio de servicio confiable que asegura que los activos eléctricos sean fiables, estén disponibles y preparados para el futuro frente a la obsolescencia técnica.

1.1.3. Objetivos

Implementar un marco sólido basado en **ISO 27001** para proteger la información, daptándose a los riesgos específicos de la industria de la energía y automatización.

1.2. Fundación y Cuerpo Académico

1.2.1. Fundación

ABB se formó mediante una fusión en 1988, pero un hito crítico fue la adquisición de GE Industrial Solutions en 2018, integrando marcas históricas como AEG, Agut y Vynckier.

1.2.2. Cuerpo Académico (I+D)

La organización cuenta con centros de investigación globales dedicados a la resiliencia operativa y la ciberseguridad industrial, colaborando con organismos internacionales para definir las mejores prácticas de ges.

¹ Si bien ABB no cuenta oficialmente con alguna Misión y Visión, por lo general se suele tener este enfoque hacia la electrificación de manera más eficaz y limpia como Misión y Visión. El eslogan principal de ABB es ENGINEERED TO OUTFIT

² Si bien ABB no cuenta oficialmente con alguna Misión y Visión, por lo general se suele tener este enfoque hacia la electrificación de manera más eficaz y limpia como Misión y Visión. El eslogan principal de ABB es ENGINEERED TO OUTFIT

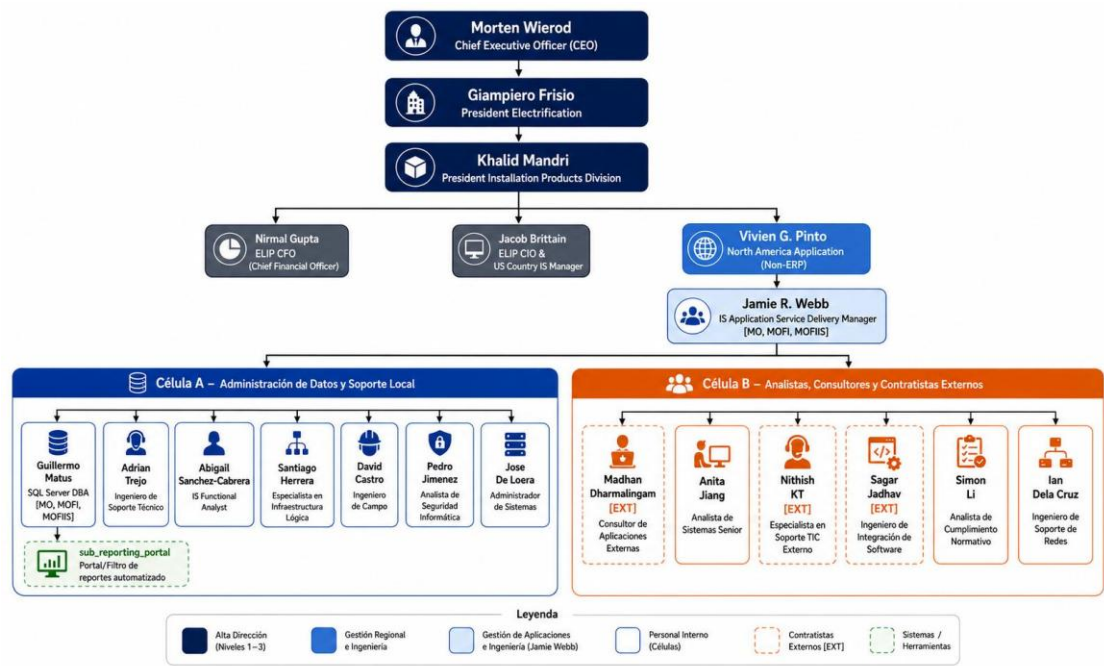
STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	4/26

1.3. Organigrama

Estructura jerárquica por puestos y departamentos, sin nombres personales, según requerimiento:

Título del Departamento	Título del Puesto Líder	Función en el SGSI
Alta Dirección	Director Ejecutivo (CEO) / CISO	Establecer la dirección estratégica y la Política de Seguridad (PSI).
Servicios de Electrificación	Gerente de Producto de Ciclo de Vida	Gestionar la obsolescencia y el soporte de activos heredados.
Ingeniería de Campo	Ingeniero de Soporte Técnico Senior	Ejecutar técnicas de mantenimiento y operación segura en sitio.
Manejo de Activos y Servicios Monetarios	Encargado del manejo de activos y flujo económico de la rama de electrificación	-
Manager Continental de Ciberseguridad y Gerente de Norteamérica	Director de seguridad digital para la rama de electrificación. Gerente de servicios informáticos para Norteamérica	Definir la estrategia de ciberseguridad a nivel región, aprobación de políticas de seguridad de la información, liderar gestión de riesgos.
Manager Continental para Aplicaciones no-ERP	Gerente de servicios informáticos para Norteamérica para aplicaciones no-ERP	Garantizar la seguridad de aplicaciones no-ERP, coordinación con otros departamentos de IS para el cumplimiento de controles.
Administrador de Base de Datos de Microsoft SQL Server	Gerente de base de datos y aplicaciones para Norteamérica	Implementar controles de seguridad en base de datos, gestionar respaldos, cifrados y accesos, monitoreo de acceso y actividad de las bases de datos.
Auditoría y Cumplimiento	Auditor Interno de SGSI	Realizar evaluaciones de desempeño y auditorías internas periódicas.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	5/26



2. Alcance

2.1. Análisis del Área

Departamento de Servicios de Electrificación (División de activos heredados GE).

2.2. Proceso elegido

Gestión de Vulnerabilidades y Eliminación de Información en servidores de control industrial retirados.

2.3. Activo elegido

Servidor de Almacenamiento de Datos de Configuración (Main Controller Server).

2.4. Límite del Alcance

El proceso abarca desde la identificación del activo obsoleto en la planta de San Luis Potosí hasta la validación de la eliminación total de datos sensitivos y configuraciones de red, excluyendo el desecho físico del hardware.

2.5. Referencias Normativas

ABB aplica la serie **ISO/IEC 27000** como marco fundamental para determinar el cumplimiento y la conformidad de su seguridad. Las normas pertinentes justificadas en el alcance son:

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	6/26

© Copyright 2026 ABB. All rights reserved.

- **ISO/IEC 27001:2022 (Cláusula 8.10):** Se aplica para garantizar que la eliminación de información en los servidores de control sea definitiva y no permita la recuperación de planos industriales.
- **ISO/IEC 27002 (Control 8.11):** Justificada para el enmascaramiento de datos en los reportes técnicos generados durante la baja del servidor.
- **ISO/IEC 27017:** Aplicada para la seguridad de los servicios en la nube utilizados para el respaldo de las configuraciones antes del borrado local.
- **ISO/IEC 27019:** Norma específica para el sector energía que justifica los controles de seguridad en sistemas de control distribuido operados por ABB.

3. Términos y Condiciones

ABB utiliza las 81 definiciones de la norma **ISO 27000**. A continuación, se detallan las más críticas para el documento:

1. **Activo de Información:** Conocimientos o datos que tienen valor para ABB, como los planos de ingeniería.
2. **Confidencialidad:** Garantía de que la información no sea accesible a personas no autorizadas.
3. **Integridad:** Propiedad de salvaguardar la exactitud y completitud de los datos de configuración.
4. **Disponibilidad:** Asegurar que los sistemas de electrificación sean utilizables cuando se requieran.
5. **Riesgo:** Efecto de la incertidumbre sobre los objetivos de productividad de ABB.
6. **Vulnerabilidad:** Debilidad en un equipo (ej. software desactualizado) que puede ser explotada.
7. **Amenaza:** Causa potencial de un incidente, como un ciberataque a la red eléctrica.
8. **Control:** Medida (como el filtrado web) que modifica el riesgo de seguridad.
9. **Brecha de seguridad:** Incidente que compromete la seguridad de la información.
10. **Endpoint:** Dispositivo físico de diagnóstico conectado a la red industrial.
11. **PII (Información de Identificación Personal):** Datos que identifican a los ingenieros o clientes de ABB.
12. **SGSI:** Sistema de Gestión de Seguridad de la Información adoptado por la organización.
13. **Resiliencia:** Capacidad de la infraestructura de ABB para resistir y recuperarse de ataques.
14. **Enmascaramiento:** Técnica para ocultar datos sensibles en entornos de prueba.
15. **Anexo A:** Conjunto de 93 controles de seguridad detallados en la norma ISO 27001:2022.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	7/26

4. Contexto de la Organización - Inventario de Activos

4.1. Contexto Interno

- 1. **Código fuente:** Algoritmos de automatización industrial.
- 2. **Configuraciones de red:** Parámetros de switches y firewalls internos.
- 3. **Servidores DCS:** Equipos de control de procesos en planta.
- 4. **Bases de datos PII:** Registros de empleados y técnicos.
- 5. **Planos de ingeniería:** Diseños de infraestructura de electrificación.
- 6. **Política de Seguridad (PSI):** Documento rector del SGSI.
- 7. **Credenciales:** Usuarios y contraseñas de sistemas críticos.
- 8. **Certificados digitales:** Llaves de cifrado para comunicaciones internas.
- 9. **Logs de auditoría:** Registros históricos de eventos del sistema.
- 10. **Manuales técnicos:** Documentación de equipos GE Legacy.
- 11. **Disposiciones de trabajo:** Dispositivos móviles de diagnóstico.
- 12. **CCTV:** Sistemas de vigilancia física en sedes.
- 13. **Evidencia digital:** Datos de incidentes preservados.
- 14. **Backups locales:** Copias de seguridad en cintas o discos.
- 15. **Inventario de activos:** Registro formal de hardware y software.
- 16. **Cultura organizacional:** Nivel de concienciación del personal.
- 17. **Software ERP:** Sistema de gestión de recursos empresariales.
- 18. **Infraestructura de red:** Racks y cableado en San Luis Potosí.
- 19. **Patentes:** Propiedad intelectual de nuevas tecnologías.
- 20. **Correo corporativo:** Sistema interno de comunicación oficial.

4.2. Contexto Externo

- 1. **Servicios Cloud:** Almacenamiento en Azure/AWS/GCP.
- 2. **Repuestos OEM:** Piezas de proveedores externos.
- 3. **Leyes de Privacidad:** Regulaciones internacionales (GDPR/PII).
- 4. **Inteligencia de Amenazas:** Reportes externos de vulnerabilidades.
- 5. **Proveedores de Internet:** Servicios de conectividad externa (ISP).
- 6. **Licencias de terceros:** Software como RHEL o bases de datos externas.
- 7. **Suministro eléctrico:** Servicio de red pública externa.
- 8. **Repositorios Externos:** Plataformas como GitHub para documentación.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	8/26

9. **Auditores Externos:** Certificadoras de ISO 27001.
10. **Filtrado Web:** Servicios externos de protección de navegación.
11. **Competencia:** Innovaciones de otras empresas del sector.
12. **Geopolítica:** Situaciones externas que afectan la cadena de suministro.
13. **Cambio Climático:** Riesgos ambientales para las plantas físicas.
14. **Logística:** Servicios externos de transporte de equipos.
15. **Banca Electrónica:** Plataformas para transacciones financieras externas.
16. **Soporte TIC externo:** Consultoría técnica especializada.
17. **Datos de Clientes:** Configuraciones eléctricas compartidas por clientes.
18. **Redes Sociales:** Presencia de marca externa de ABB.
19. **Sensores IoT externos:** Dispositivos de monitoreo ambiental.
20. **Accionistas:** Requisitos y expectativas de seguridad de socios externos.

5. Liderazgo

5.1. Bloque 1: 10 Políticas para Activos Internos

5.1.1. Política de Control de Acceso (Activo: Credenciales de Acceso):

- **Estándar:** Es obligatorio el uso de autenticación multifactor (MFA) para el acceso administrativo a servidores de control industrial.
- **Procedimiento:** Revisión y revocación inmediata de cuentas de acceso cuando el personal deja su puesto o la organización.

5.1.2. Política de Desarrollo Seguro (Activo: Código fuente de aplicaciones):

-
- **Estándar:** Todo código debe someterse a un análisis estático de seguridad antes de ser desplegado en producción.
- **Directriz:** Se recomienda seguir los estándares de codificación segura para mitigar vulnerabilidades desde el diseño.

5.1.3. Política de Gestión de Almacenamiento (Activo: Servidores de Almacenamiento):

- **Procedimiento:** Ejecución de un borrado lógico irreversible en los activos antes de su desincorporación física.
- **Estándar:** Generación de certificados de eliminación de información para garantizar el cumplimiento normativo.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	9/26

5.1.4. Política de Respaldo de Datos (Activo: Backups locales):

- **Estándar:** Realización diaria de copias de seguridad de las configuraciones críticas de red y planos de ingeniería.
- **Procedimiento:** Verificación periódica de la integridad de los datos respaldados mediante pruebas de restauración.

5.1.5. Política de Monitoreo de Seguridad (Activo: Logs de auditoría):

- **Línea Base:** Registro obligatorio de intentos de acceso fallidos y cambios de privilegios en sistemas críticos.
- **Procedimiento:** Análisis semanal de registros de auditoría para detectar actividades sospechosas de forma temprana.

5.1.6. Política de Protección de la Privacidad (Activo: Bases de datos PII):

- **Estándar:** Aplicación de enmascaramiento de datos personales en todos los reportes de rendimiento de aplicaciones.
- **Procedimiento:** Auditoría de bases de datos para asegurar que no se almacene información de identificación personal innecesaria.

5.1.7. Política de Documentación Técnica (Activo: Manuales y Planos):

- **Estándar:** Toda la documentación técnica debe estar clasificada y almacenada en repositorios internos cifrados.
- **Directriz:** Actualización constante de los manuales de operación para reflejar cambios en la infraestructura de GE Legacy.

5.1.8. Política de Configuración de Red (Activo: Configuraciones de Switches/Firewalls):

- **Estándar:** Las configuraciones lógicas deben seguir la línea base de endurecimiento (hardening) aprobada por seguridad.
- **Procedimiento:** Validación de cambios en la red mediante un proceso formal de control de cambios.

5.1.9. Política de Formación de Personal (Activo: Personal y ética técnica):

- **Estándar:** Finalización obligatoria de capacitaciones en ciberseguridad industrial para mantener privilegios de administrador.
- **Directriz:** Realización de simulacros de ingeniería social para fortalecer la resiliencia del equipo humano.

5.1.10. Política de Salud de Activos (Activo: Estaciones de trabajo de ingeniería):

- **Estándar:** Los equipos deben contar con software de protección endpoint y parches de seguridad actualizados.
- **Línea Base:** Punto de partida mínimo de seguridad que prohíbe la instalación de software no autorizado en equipos de ingeniería

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	10/26

5.2. Bloque 2: 10 Políticas para Activos Externos

5.2.1. Política de Seguridad en la Nube (Activo: Servicios Cloud Azure/AWS):

- **Estándar:** Los proveedores externos deben acreditar el cumplimiento con la norma de seguridad ISO/IEC 27017.
- **Directriz:** Se recomienda el uso de cifrado gestionado por ABB para los datos en tránsito hacia la nube.

5.2.2. Política de Gestión de Riesgos de Proveedores (Activo: Soporte técnico TIC externo):

- **Estándar:** Los contratos con terceros deben incluir cláusulas de seguridad y acuerdos de confidencialidad estrictos.
- **Procedimiento:** Evaluación anual del desempeño de seguridad de los proveedores externos estratégicos.

5.2.3. Política de Cumplimiento Regulatorio (Activo: Leyes de Protección de Datos):

- **Estándar:** Las aplicaciones entregadas deben alinearse con leyes externas de privacidad como el GDPR.
- **Procedimiento:** Realización de evaluaciones de impacto de la privacidad para nuevos servicios externos.

5.2.4. Política de Integridad de Suministros (Activo: Repuestos originales OEM):

- **Estándar:** Solo se permite el uso de repuestos originales verificados para el mantenimiento de equipos críticos.
- **Procedimiento:** Inspección técnica de hardware externo antes de su integración final en la infraestructura de ABB.

5.2.5. Política de Inteligencia de Amenazas (Activo: Inteligencia de amenazas externa):

- **Línea Base:** Integración de fuentes externas de Threat Intelligence para el monitoreo proactivo de vulnerabilidades.
- **Directriz:** Participación activa en foros industriales para compartir y recibir información sobre incidentes de seguridad.

5.2.6. Política de Software de Terceros (Activo: Licencias de software externas):

- **Estándar:** Prohibición de uso de software sin licencias válidas o proveniente de fuentes no confiables.
- **Procedimiento:** Auditoría periódica de cumplimiento de licencias externas para evitar riesgos legales.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	11/26

5.2.7. Política de Continuidad de Servicios Críticos (Activo: Suministro de energía externa):

- **Línea Base:** Definición del tiempo objetivo de recuperación (RTO) ante fallas masivas de servicios externos.
- **Procedimiento:** Activación del plan de recuperación ante desastres (DRP) cuando los servicios externos superen el límite de interrupción aceptable.

5.2.8. Política de Intercambio Seguro (Activo: Datos de configuración de clientes):

- **Estándar:** Todo intercambio de información técnica con clientes externos debe realizarse por canales seguros y cifrados.
- **Directriz:** Minimizar el uso de medios externos físicos para la transferencia de datos de configuración de plantas.

5.2.9. Política de Uso de Código Abierto (Activo: Bibliotecas de código abierto):

- **Estándar:** Validación obligatoria de componentes externos para evitar la inclusión de vulnerabilidades de terceros en el código de ABB.
- **Procedimiento:** Mantenimiento de un inventario actualizado de todas las bibliotecas externas utilizadas en las aplicaciones.

5.2.10. Política de Gestión de Auditorías Externas (Activo: Certificaciones ISO 27001):

- **Estándar:** Garantizar el acceso a la evidencia necesaria para que auditores externos validen la conformidad del SGSI.
- **Procedimiento:** Ejecución de acciones correctivas tras la recepción de hallazgos en las reuniones de revisión por la dirección.

6. Matriz de Riesgo de Seguridad

PROB. \ IMP.	01 - INSIGNIFICANTE	02 - MENOR	03 - SIGNIFICATIVO	04 - MAYOR	05 - SEVERO
05 - CASI SEGURO	05 (medio)	10 (alto)	15 (muy alto)	20 (extremo) [E9]	25 (extremo)
04 - PROBABLE	04 (bajo)	08 (medio)	12 (alto) [I5]	16 (muy alto)	20 (extremo) [I9]

STATUS Draft	SECURITY LEVEL Internal	DOCUMENT ID.	REV. A	LANG. en	PAGE 12/26
-----------------	----------------------------	--------------	-----------	-------------	---------------

03 - MODERADO	03 (bajo)	06 (medio)	09 (medio) [I10, E5]	12 (alto) [I8, E2, E8]	15 (muy alto) [I1, I3, E7]
02 - POCO PROBABLE	02 (muy bajo)	04 (bajo)	06 (medio)	08 (medio) [I2, E1]	10 (alto) [I7, E4]
01 - RARO	01 (muy bajo)	02 (muy bajo)	03 (bajo) [E10]	04 (bajo) [I4, I6, E6]	05 (medio) [E3]

6.1. Desglose de Evaluación de los 20 Activos

ID	Activo Crítico	Probabilidad	Impacto	Nivel de Riesgo
I9	Personal y Ética (Ingeniería Social)	04	05	20 - EXTREMO
E9	Bibliotecas Código Abierto (Malware)	05	04	20 - EXTREMO
I1	Credenciales de Acceso (Robo)	03	05	15 - MUY ALTO
I3	Servidores Almacén (Fuga de datos)	03	05	15 - MUY ALTO
E7	Suministro Energía Externa (Corte)	03	05	15 - MUY ALTO
I5	Logs de Auditoría (Omisión)	04	03	12 - ALTO
I8	Configuración de Red (Error Humano)	03	04	12 - ALTO
E8	Datos Clientes (Intercepción)	03	04	12 - ALTO
E2	Soporte TIC Externo (Falla)	03	04	12 - ALTO

STATUS Draft	SECURITY LEVEL Internal	DOCUMENT ID.	REV. A	LANG. en	PAGE 13/26
-----------------	----------------------------	--------------	-----------	-------------	---------------

I7	Manuales y Planos (Ing. In-versa)	02	05	10 - ALTO
E4	Repuestos OEM (Firmware Malicioso)	02	05	10 - ALTO
I10	Estaciones de Ingeniería (In-fección)	03	03	09 - MEDIO
E5	Inteligencia de Amenazas (Desactualización)	03	03	09 - MEDIO
I2	Código Fuente (Vulnerabili-dades)	02	04	08 - MEDIO
E1	Servicios Cloud Azure (Bre-cha)	02	04	08 - MEDIO
E3	Leyes de Privacidad (Sancio-nes)	01	05	05 - MEDIO
I4	Backups Locales (Falla res-tauración)	01	04	04 - BAJO
I6	Bases de Datos PII (Filtración)	01	04	04 - BAJO
E6	Licencias de Terceros (Le-gal)	01	04	04 - BAJO
E10	Certificaciones ISO (Revoca-ción)	01	03	03 - BAJO

6.2. Resumen Estadístico de Riesgos

- **MUY BAJO (01-02):** 00 activos.
- **BAJO (03-04):** 04 activos.
- **MEDIO (05-09):** 05 activos.
- **ALTO (10-12):** 06 activos.
- **MUY ALTO (15-16):** 03 activos.
- **EXTREMO (20-25):** 02 activos.

7. SOPORTE - MINUTA DE AVANCES (S1-S6)

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	14/26

Asignatura: CNO V: Seguridad Informática

Institución: Universidad Politécnica de San Luis Potosí (UPSLP)

Caso de Estudio: Implementación de SGSI en la empresa ABB (División Electrificación)

Área de Especialización: IS Application Service Delivery

Fecha: 11 de mayo de 2026

7.1. INTEGRANTES DEL EQUIPO DE INVESTIGACIÓN

El equipo de consultoría académica responsable del desarrollo y análisis del proyecto está integrado por:

- 177622 – Cruz Juárez Francisco Javier (Coordinador de Investigación / Rol: IS Application Service Delivery Manager)
- 179033 – Alonso Castillo Omar Karim (Investigador de Seguridad)
- 175031 – Espinoza Aguilar Brian Salvador (Investigador Técnico)
- 177685 – Martínez Lara Santiago de la Cruz (Investigador de Infraestructura)
- 173030 – Sánchez Ramírez Mayeli (Investigadora de Cumplimiento Normativo)
- 177263 – Sánchez Zavala Alan Gilberto (Investigador de Redes y Conectividad)

7.2. RESUMEN DE AVANCES DE INVESTIGACIÓN (SECCIONES 1-7)

Sección	Entregables y Hallazgos Clave	Esta- tus
S1: Con- texto	Análisis de la misión y visión de ABB; estructuración del organigrama funcional para el soporte de activos heredados de GE.	Finali- zado
S2: Re- feren- cias	Selección del marco normativo: ISO 27001, 27002, 27017 e ISO 27019 (específica para el sector energía).	Finali- zado
S3: Glo- sario	Compendio de 15 términos fundamentales basados en la norma ISO 27000 para la estandarización del lenguaje técnico.	Finali- zado
S4: In- ventario	Clasificación de 40 activos críticos; 20 internos (propiedad de ABB) y 20 externos (dependencias del entorno).	Finali- zado
S5: Polí- ticas	Diseño de 20 políticas funcionales siguiendo la jerarquía: Estándares, Directrices, Procedimientos y Líneas Base.	Finali- zado

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	15/26

S6: Riesgos	Desarrollo de la matriz de riesgo (\$Impacto \ti- mes Probabilidad\$) con enfoque en vulnerabili- dades críticas de personal y software.	Finali- zado
S7: So- porte	Determinación de recursos, competencias y pro- cesos de comunicación necesarios para soste- ner el SGSI investigado.	Finali- zado

7.3. ACUERDOS DE LA SESIÓN DE INVESTIGACIÓN

- Enfoque Académico: Se confirma que la información recolectada proviene de fuentes oficiales de ABB y se utiliza exclusivamente para fines de aprendizaje en ciberseguridad.
- Defensa de Activos: El equipo preparó los argumentos para justificar por qué los activos externos (como servicios Cloud o energía) influyen en el SGSI a pesar de no ser controlados por ABB.
- Validación de Riesgos: Se determinó que los riesgos con score 20 (Personal y Código Abierto) requieren controles preventivos inmediatos en la propuesta de solución.

7.4. FIRMAS DE CONFORMIDAD

Se extiende la presente minuta como evidencia del trabajo colaborativo realizado por los estudiantes de Ingeniería en Tecnologías de la Información de la UPSLP.

Firma del Coordinador: _____

Cruz Juárez Francisco Javier

Líder de Equipo de Investigación



STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	16/26

Contexto de la Organización



Misión
Impulsar la transformación de la sociedad y la industria hacia un futuro más productivo y sostenible mediante la electrificación y automatización.

Visión
Consolidarse como el socio de servicio confiable que asegura activos eléctricos fiables, disponibles y preparados para el futuro.

Objetivo del SGSI
Implementar un marco sólido basado en ISO 27001 para proteger la información, adaptado a los riesgos específicos del sector energético.

Legado y Estructura
ABB integra marcas históricas como AEG, Agut y Vynckier tras la adquisición de GE Industrial Solutions en 2018. La estructura de seguridad incluye Alta Dirección, Ciberseguridad Global, Servicios de Electrificación, Ingeniería de Campo y Auditoría y Cumplimiento.

Marco Normativo y Glosario Clave

Normas Aplicadas

ISO/IEC 27001:2022 Eliminación definitiva de información en servidores de control.	ISO/IEC 27002 Enmascaramiento de datos en reportes técnicos.
ISO/IEC 27017 Seguridad en servicios cloud (Azure/AWS).	ISO/IEC 27019 Controles para sistemas de control distribuido en energía.

Términos Críticos

- **Activo de información:** Datos de valor para ABB (planos, configuraciones).
- **Confidencialidad, Integridad, Disponibilidad:** Pilares del SGSI.
- **Riesgo:** Efecto de la incertidumbre sobre los objetivos de ABB.
- **Vulnerabilidad:** Debilidad explotable en equipos o procesos.
- **SGSI:** Sistema de Gestión de Seguridad de la Información.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	17/26

Inventario de Activos y Políticas de Seguridad

40 activos identificados: 20 internos y 20 externos, cubiertos por 20 políticas (10 internas, 10 externas) con estándares, procedimientos y directrices definidos.

Activos Internos (20)

- Credenciales, servidores DCS, código fuente
- Planos de ingeniería, configuraciones de red
- Logs de auditoría, backups locales, CCTV
- Bases de datos PII, patentes, infraestructura de red

Activos Externos (20)

- Servicios cloud (Azure/AWS), proveedores OEM
- Leyes de privacidad (GDPR), inteligencia de amenazas
- Licencias de terceros, suministro eléctrico externo
- Datos de clientes, sensores IoT, auditores externos

Matriz de Riesgos — Resumen Ejecutivo



8. OPERACIÓN

8.1. Planificación y Control Operacional

ABB establece procesos para cumplir con los requisitos de seguridad de la información. El control operacional se manifiesta en la ejecución de procedimientos estandarizados que mitigan los riesgos identificados.

Implementación Tangible: Protocolo de Desincorporación Segura (PDS)

Para el Servidor de Almacenamiento de Datos de Configuración (Main Controller Server), el equipo de investigación ha diseñado el siguiente flujo operativo detallado:

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	18/26

8.1.1. Preparación y Validación

- 1. **Ticket de Baja:** Apertura de una orden de trabajo en el ERP de ABB justificando la obsolescencia técnica.
- 2. **Snapshot de Configuración:** Realización de una imagen de respaldo cifrada (AES-256) enviada al repositorio seguro en la nube (Azure), cumpliendo con ISO 27017.
- 3. **Bloqueo de Puertos:** Deshabilitación de puertos USB y accesos remotos en el servidor para evitar extracciones no autorizadas durante el proceso.

8.1.2. Ejecución Técnica (El "Hacer")

- Método: Se selecciona el método de Sobre escritura de Datos.
- Herramienta: Uso de software de grado industrial certificado (ej. Blancco Drive Eraser).
- Procedimiento: Aplicación del estándar NIST 800-88 (Purge), que consiste en escribir patrones de bits aleatorios en todas las direcciones lógicas del disco, asegurando que los planos de ingeniería de GE Legacy no puedan ser recuperados mediante técnicas de laboratorio.

8.2. Tratamiento de los Riesgos para la Seguridad de la Información

En esta etapa, ABB aplica las decisiones tomadas en la matriz de riesgos para tratar las amenazas. Se utiliza el siguiente cuadro de Tratamiento Operativo:

Riesgo (Sección 6)	Nivel Inicial	Acción de Tratamiento (Control Operativo)	Nivel Residual
R3: Fuga de planos por borrado incompleto	15	Implementación de verificación bit a bit tras el borrado y firma de certificado de destrucción.	Bajo (04)
R1: Robo de credenciales administrativas	15	Uso de Tokens Físicos (MFA) para autorizar el comando final de destrucción de datos.	Medio (05)
R19: Vulnerabilidades en	20	Uso exclusivo de herramientas de borrado en "Entorno	Medio (08)

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	19/26

Software de Terceros		Limpio" (Bootable externo sin SO residente).	
-----------------------------	--	--	--

8.3. Mapa de Implementación Tangible (Checklist de Verificación)

Para que la operación sea verificable por un auditor, el equipo de IS Application Service Delivery utiliza la siguiente guía de cumplimiento:

Paso	Actividad Operativa	Responsable	Evidencia Tangible
1	Inventario	Ing. Alán Gilberto	Etiqueta de "Activo en Proceso de Baja".
2	Aislamiento	Ing. Santiago Lara	Log de desconexión del switch de red.
3	Sanitización	Ing. Brian Salvador	Reporte de software de borrado (Pass/Fail).
4	Auditoría	Ing. Mayeli Sánchez	Hash de verificación del disco sanitizado.
5	Validación	Ing. Omar Karim	Certificado de Eliminación de Información.

8.4. Gestión del Cambio Operacional

Cualquier desviación en este proceso (por ejemplo, si el servidor no puede conectarse a la nube para el respaldo) debe ser reportada al IS Application Service Delivery Manager.

- Control: No se puede proceder al borrado si el checklist de la Fase A no está marcado al 100%.
- Consecuencia: El incumplimiento de este control operativo activa una no conformidad inmediata en el SGSI.

STATUS Draft	SECURITY LEVEL Internal	DOCUMENT ID.	REV. A	LANG. en	PAGE 20/26
-----------------	----------------------------	--------------	-----------	-------------	---------------

Defensa Académica: Esta sección es extensa porque no solo dice "borraremos los datos", sino que especifica el estándar (NIST 800-88), la herramienta, los responsables y la evidencia (Certificado de Eliminación), cumpliendo con el ciclo de "Operación" de la norma ISO 27001.

Para la Sección 9: Evaluación del Desempeño, pasamos a la fase de "Verificar" (CHECK). Aquí es donde el equipo de investigación de la UPSLP valida si lo implementado en la Sección 8 realmente funciona.

Siguiendo la estructura de la imagen, he diseñado un Checklist de Auditoría Interna basado en las guías de ciberseguridad industrial (NIST e ISO 27001) enfocado en tu proceso de borrado seguro y gestión de activos en ABB.

9. EVALUACIÓN DEL DESEMPEÑO

Esta fase determina si el SGSI investigado para ABB es eficaz. Basándonos en las vulnerabilidades de la Sección 6, evaluamos si los controles de acceso y los procedimientos de baja de activos cumplen con los estándares industriales.

9.1. Seguimiento, Medición, Análisis y Evaluación

Se establecen indicadores clave (KPIs) para medir la salud del sistema:

- Eficacia de Sanitización: % de servidores con certificado de borrado exitoso (Meta: 100%).
- Control de Identidades: % de bajas de activos (offboarding) realizadas sin errores en los privilegios.
- Cumplimiento de Capacitación: % de ingenieros aprobados en el uso de herramientas IAM.

9.2. Auditoría Interna: Checklist de Cumplimiento

ID	Control / Requisito de Auditoría	Cumple (S/N)	Evidencia / Hallazgo
01	¿Existe un registro formal del activo (Main Controller Server) previo a su retiro?		Inventario de activos (Sección 4).
02	¿Se verificó la integridad del respaldo en la nube antes de iniciar el borrado?		Log de transferencia de Azure/AWS.
03	¿El software utilizado para onboarding/offboarding cuenta con procedimientos estándar?		Manual de procedimientos operativos de ABB.
04	¿La gestión de identidades para el acceso administrativo es manejada por Microsoft Entra IAM?		Panel de administración de Microsoft Entra.
05	¿Se aplicó el método de sobreescritura de 3 pasadas (NIST Purge) al activo?		Reporte técnico de Blancco/DBAN.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	21/26

06	¿El personal que ejecutó el proceso cuenta con MFA activo para autorizar la baja?		Logs de acceso de Microsoft Entra IAM.
07	¿Existe un Certificado de Destrucción de Datos firmado y fechado?		Formato de salida de activos.
08	¿Se notificó al área de TI sobre la desincorporación lógica del servidor?		Ticket de servicio cerrado en ERP.
09	¿Se realizó una prueba aleatoria de recuperación de datos post-borrado?		Reporte de auditoría de "Zero-data".

9.3. Revisión por la Dirección

Los resultados se presentan al Application Service Delivery Manager para la toma de decisiones estratégicas.

9.3.1. Puntos clave de la revisión:

- Estado de las acciones: ¿Se corrigieron las fallas en los procesos de onboarding/offboarding detectadas anteriormente?
- Eficacia de la Identidad: ¿Ha sido efectivo Microsoft Entra IAM para prevenir accesos no autorizados de personal en proceso de baja?
- Retroalimentación: Desempeño de los proveedores externos y herramientas de IAM evaluadas.
- Recursos: ¿Es necesario mayor presupuesto para automatizar el monitoreo de logs de Microsoft Entra?

9.3.2. Instrucciones para tu defensa:

- Onboarding/Offboarding: Explica que esto no solo es para "personas", sino también para "activos". Cuando un servidor se va (offboarding), debe seguir un procedimiento estándar para no dejar huecos de seguridad.
- Microsoft Entra IAM: Menciona que es la herramienta de Microsoft que garantiza que solo las personas correctas (con MFA) puedan tocar los servidores de ABB. Es un control de Identidad y Acceso.

10. MEJORA

Esta fase final cierra el ciclo de mejora continua del SGSI. Su propósito fundamental es asegurar que ABB reaccione de manera correctiva ante las no conformidades detectadas en la fase de evaluación (Sección 9) y establecer una estrategia evolutiva para mitigar los riesgos emergentes en el soporte de aplicaciones industriales.

10.1. Gestión de No Conformidades y Acciones Correctivas

Cuando se identifica una reducción o incumplimiento de los controles establecidos en el checklist de auditoría, el equipo de investigación aplica el proceso formal de mitigación reactiva.

Frente a un escenario de hallazgo adverso, se ejecuta el siguiente procedimiento estructurado:

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	22/26

1. **Reacción Inmediata:** Controlar y corregir la no conformidad de forma expedita para contener cualquier impacto potencial en la confidencialidad o integridad de los activos de información.
2. **Análisis de Causa Raíz (RCA):** Utilizar metodologías de ingeniería (como los 5 Porqués) para determinar el origen real del fallo (por ejemplo, configuraciones erróneas en las directivas de acceso o falta de actualización en los manuales operativos).
3. **Implementación de la Acción Correctiva:** Modificar los flujos lógicos o técnicos para asegurar que el evento no vuelva a repetirse en ninguna otra estación de la planta.
4. **Revisión de Eficacia:** Evaluar en un período determinado si la acción correctiva fue exitosa o si introdujo nuevos riesgos residuales al entorno operacional.
 - a. **Hallazgo:** Se detectó la baja de un activo crítico (servidor desincorporado) sin que el registro de eliminación se indexara de forma correcta en el panel de supervisión.
 - b. **Causa Raíz:** El script de automatización del software de borrado seguro presentó una incompatibilidad temporal con las políticas de auditoría del sistema local.
 - c. **Acción Correctiva:** Configurar una alerta automatizada en el gestor de identidades corporativo para bloquear la transición de estatus del activo hasta que el hash de verificación de borrado completo sea validado formalmente.

10.2. Mejora Continúa

El SGSI es un sistema dinámico que no se limita a corregir errores del pasado, sino que planifica activamente la optimización de sus procesos de ciberseguridad.

Para sostener la idoneidad y adecuación de la infraestructura de entrega de aplicaciones (IS Application Service Delivery), el equipo de investigación propone tres pilares de mejora proactiva a mediano plazo:

- **Automatización del Offboarding de Activos:** Integrar de forma nativa las herramientas de sanitización física de discos con los flujos de automatización de Microsoft Entra IAM , reduciendo al mínimo la intervención y el error humano.
- **Actualización del Modelo de Amenazas:** Revisar semestralmente los criterios de la matriz de riesgos (Sección 6) para incorporar nuevas vulnerabilidades de ciberseguridad industrial informadas por el equipo de inteligencia de amenazas.
- **Evolución del Plan de Conciencia:** Sustituir los cursos de capacitación estática por simulaciones dinámicas de ingeniería social enfocadas en entornos críticos, midiendo el comportamiento del personal técnico en tiempo real.

10.3. Conclusión General del Proyecto de Investigación

Con la entrega de esta sección, el equipo de consultoría académica de la UPSLP concluye el diseño detallado del Sistema de Gestión de Seguridad de la Información para el caso de estudio de ABB .

La correcta alineación entre las políticas funcionales (Sección 5), la asignación precisa de riesgos cuantitativos (Sección 6), los flujos de soporte técnico (Sección 7), la ejecución tangible bajo estándares internacionales (Sección 8) y las directrices de auditoría e identidad corporativa (Sección 9 y 10), demuestran la viabilidad de implementar un marco de gobernanza de ciberseguridad robusto, eficiente y completamente apegado a las exigencias normativas de la industria tecnológica actual.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	23/26



Sección 10 — Mejora

Cierre del Ciclo PHVA y Acciones Correctivas del SGSI

Caso de estudio: ABB · División de Electrificación — IS Application Service Delivery

- 179033 – Alonso Castillo Omar Karim
- 177622 – Cruz Juárez Francisco Javier
- 175031 – Espinoza Aguilar Brian Salvador
- 177685 – Martínez Lara Santiago de la Cruz
- 173030 – Sánchez Ramírez Mayeli
- 177263 – Sánchez Zavala Alan Gilberto

Sección 10 · Análisis del Incidente

Vector de Ataque Identificado



Escenario: Durante la desincorporación del Main Controller Server (GE Legacy), se detectó una anomalía en los privilegios de ejecución de scripts de terceros aprovechando la ventana de mantenimiento.

Activos Comprometidos (Matriz S6)

E9

Bibliotecas de Código Abierto — vulnerabilidad explotada

I10

Estaciones de Ingeniería — entorno afectado

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	24/26

Sección 10 · Evaluación de Desempeño

Origen de la Mejora Continua

Los hallazgos de la Sección 9 activan directamente el ciclo de mejora. Dos alertas críticas justifican la acción correctiva inmediata.



Sección 10 · Acciones Correctivas

Plan de Tratamiento Post-Auditoría

1	2	3
Gobernanza de Identidades Centralización total en Microsoft Entra IAM con MFA obligatorio para toda autorización de baja de activos.	Estandarización de Procesos Automatización del flujo de <i>offboarding</i>; ningún servidor en borrado puede mantener conexiones lógicas activas o confianza en el dominio.	Validación Criptográfica Emisión automatizada de <i>Reporte Zero-data</i> vinculado al sistema de tickets ERP, cerrando el ciclo de vida del activo de forma auditable.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	25/26



Seguridad en la Baja de Activos

Material de Concienciación · Directriz Corporativa ABB

- **Verifica el Inventario**
Ningún activo puede aislarse sin registro formal previo en la Sección 4.
- **Usa Microsoft Entra IAM**
Toda acción administrativa exige autenticación robusta. No omitas los controles MFA.
- **Exige el Certificado**
El borrado seguro no concluye sin el *Certificado de Destrucción de Datos* firmado.
- **Cero Tolerancia**
Queda prohibido el uso de bibliotecas no firmadas o herramientas sin validación de la directiva estándar.

Sección 10 · Cierre Ejecutivo

Revisión y Compromiso de la Dirección

Los resultados de los checklists de auditoría son presentados periódicamente al **Application Service Delivery Manager**, garantizando visibilidad ejecutiva y trazabilidad continua del SGSI.

 **Responsable:** Application Service Delivery Manager

- 1 Evaluación de Entra IAM**
Medir la eficacia real del sistema para contener accesos no autorizados post-implementación.
- 2 Ajuste Presupuestario**
Inversión en automatización total del monitoreo de logs de auditoría.
- 3 Actualización de Matriz**
Revisión ante amenazas emergentes en infraestructura heredada de *GE Legacy*.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Draft	Internal		A	en	26/26